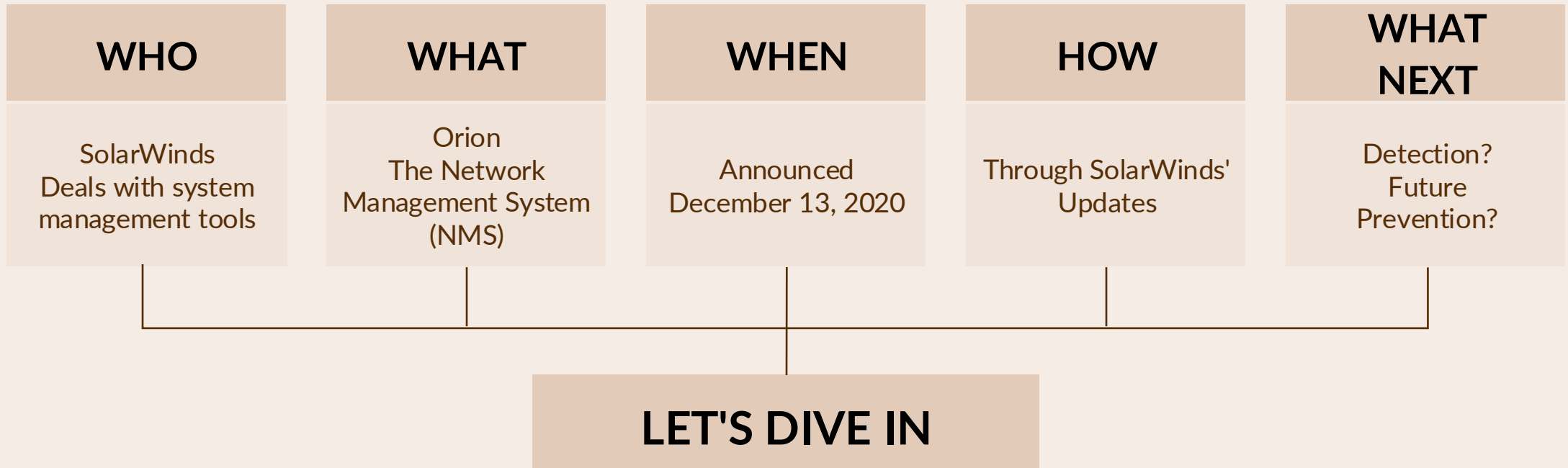




Don't Get Burnt

A Look into the 2020
SolarWinds Attack

BACKGROUND



THE WHO

The Providers

- SolarWinds specializes in systems management tools for IT professionals
- Most deployed product is Orion
- Based in Austin, Texas

The Attackers

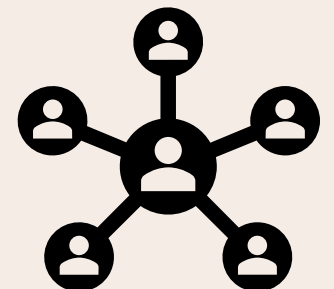
- UNC2452 or APT29?
- Tracked by SolarWinds under UNC2452
- By April of 2021 merged/contributed to APT29
- Linked to Russian Foreign Intelligence Service (SVR)

The Effected

- Over 300,000 customers
- Include: US Government and 425 of Fortune 500 companies
- Exact number of effected by malicious updates unknown
- Anyone who downloaded updates could be at risk

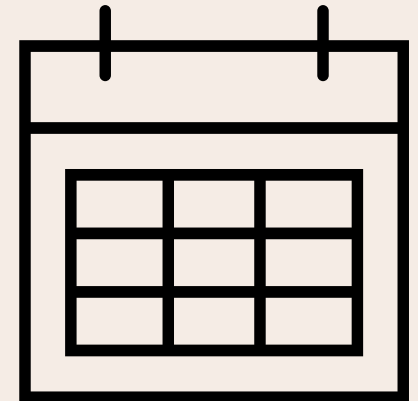
THE WHAT

- Targeted NMS because they require communication with all managed and monitored devices
- Many are configured to monitor and respond to events
- Changes it can make, the attacker can make
- Compromised NMS can allow attackers to reshape network traffic to gain Man in the Middle (MitM) attacks
- Malicious updates led to breaches like the ones of the US Treasury and Commerce Department in which their emails were monitored for months and credentials compromised



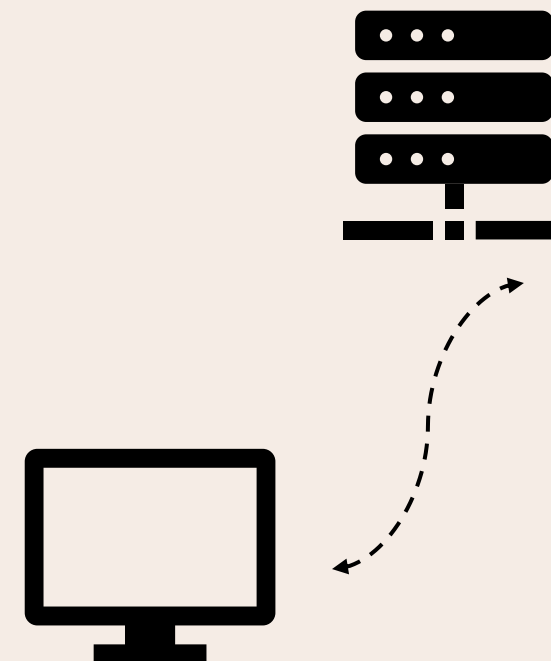
THE WHEN

- Story broke December 13th, 2020 with Chris Bing of Reuters and later Ellen Nakashima with the Washington Post
- Effected updates from March to June of 2020 but not reported/found until December 13th following the December 8th press release that FireEye had also been attacked (same group responsible)
- Of their 300,000 customers, roughly 18,000 effected by the malicious updates



THE HOW

- The sunburst backdoor, a trojanized version of a SolarWinds Orion plug-in that's a digitally signed component of the software framework
- When effected updates were standard Windows Installer Patch file and when installed, malicious DLL was loaded with other legitimate functions
- Malware would lay dormant for up to two weeks before attempting to resolve subdomain
- Eventually leading to its C2 traffic leading to malicious domains mimicking normal API communications through the Orion Improvement Program (OIP)



WHAT NEXT?

- Assume compromise
- If using other products than Orion, consider they might also be compromised when mapping your attack surface
- Zero Trust Networking—block access from your NMS to the internet
- Change passwords for accounts with access to SolarWinds servers and infrastructure
- Focus of Discovery not Detection COA



REFERENCES

- SANS Institute. *What You Need to Know About the SolarWinds Supply-Chain Attack* | SANS Institute. 16 Aug. 2024, www.sans.org/blog/what-you-need-to-know-about-the-solarwinds-supply-chain-attack.
- Bing, Christopher. “Suspected Russian hackers spied on U.S. Treasury emails - sources.” *Reuters*, 13 Dec. 2020, www.reuters.com/article/us-usa-cyber-treasury-exclusive/suspected-russian-hackers-spied-on-u-s-treasury-emails-sources-idUSKBN28N0PG.
- Mandiant. “SolarWinds Supply Chain Attack Uses SUNBURST Backdoor.” *Google Cloud Blog*, 13 Dec. 2020, cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor.
- *APT29, IRON RITUAL, IRON HEMLOCK, NobleBaron, Dark Halo, NOBELIUM, UNC2452, YTTRIUM, the Dukes, Cozy Bear, CozyDuke, SolarStorm, Blue Kitsune, UNC3524, Midnight Blizzard, Group G0016* | MITRE ATT&CK®. attack.mitre.org/groups/G0016.